

GESTÃO DE RISCOS DE IA

GOVERNANÇA E SEGURANÇA

Manual Prático para Gerentes e Analistas Juniores

O que este manual faz: Explica como aprovar, mapear, testar, proteger, monitorar e comprovar o uso responsável de IA. Ele abrange aprendizado de máquina tradicional, IA generativa, RAG (Random Access Groups - Ações de Aprovação, Mapeamento e Garantia), agentes, ferramentas, NIST AI RMF (Nist Standards Institute for Technology and Technology) - Modelo de Gerenciamento de Riscos de IA (NIST AI RMF), normas ISO, riscos OWASP, CSA AICM (California Safety and Assessment Management - Gestão de Riscos de IA da CSA), decisões gerenciais, trabalho de analistas e laboratórios seguros.

Alberto (AI) Leiva

Primeira edição • julho de 2026

Prefácio

A inteligência artificial pode auxiliar pessoas, criar conteúdo, classificar opções, detectar padrões e tomar decisões. No entanto, também pode ser falha, tendenciosa, manipulada, excessivamente poderosa, difícil de explicar ou usada além de sua finalidade aprovada. Uma boa governança ajuda uma organização a obter valor, protegendo pessoas, informações, operações e a confiança.

Este manual utiliza linguagem simples e foca-se no trabalho prático. Não se trata de aconselhamento jurídico, guia de certificação ou garantia de que um sistema é seguro. Leis, normas, comportamentos de modelos, ameaças e funcionalidades de fornecedores mudam rapidamente. Consulte fontes oficiais atualizadas e envolva profissionais qualificados nas áreas jurídica, de privacidade, segurança, ciência de dados, direitos humanos, segurança da informação, compras, auditoria e negócios para a tomada de decisões importantes.

Nota sobre informações atuais: Verificado em 14 de julho de 2026. O NIST AI RMF 1.0 permanece como a estrutura publicada, mas o NIST afirma que está sendo revisado. O NIST AI 600-1 permanece como o Perfil de IA Generativa. O CSA AICM v1.1 foi lançado em junho de 2026. As obrigações da Lei de IA da UE aplicam-se progressivamente, e as alterações de prazos propostas não são lei definitiva, a menos que sejam adotadas; verifique o status com fontes oficiais e assessoria jurídica.

Como usar este manual

- Gestores: comecem pelos capítulos 1 a 10 e 22 a 28 e, em seguida, utilizem os registros de decisão do capítulo 30.
- Analistas juniores: estudem na ordem, executem apenas laboratórios autorizados e construam o portfólio do Capítulo 29.
- Desenvolvedores e equipes de dados: concentrem-se nos capítulos 10 a 23 e nas ferramentas de teste do capítulo 26.
- Equipes de GRC, privacidade, jurídica e de auditoria: concentrem-se nos capítulos 2 a 9 e 20 a 25.
- Registre o sistema exato, o modelo, a versão, os dados, o uso, os usuários, a localização geográfica, o impacto, as evidências, as limitações e a decisão para cada avaliação.

Índice

Este arquivo contém um sumário nativo do Word, além de um guia de capítulos permanente com numeração de páginas.

Prefácio	2
Como usar este manual	2
Índice	3
Guia do Capítulo	7
1. Fundamentos de IA e Uso Confiável	8
1.1 Características confiáveis	8
2. Governança, Normas e Cenário Jurídico	9
2.1 Registo legal e de obrigações	9
10	
do NIST AI RMF	
4. GOVERNAR: Cultura, Responsabilidade e Política	
4.1 Estrutura de governança	
5. MAPA: Contexto, Pessoas e Impacto	
5.1 Registro de contexto	
6. MEDIR: Testes e Análise de Risco	
6.1 Plano de medição	
7. GERENCIAR: Tratamento, Implantação e Melhoria	
7.1 Portão de implantação	
8. Perfil	
9. ISO/IEC 42001 e ISO/IEC 23894	
9.1 Certificação e advertências sobre direitos autorais	
10. Inventário de IA, casos de uso e ciclo de vida	
10.1 Controles do ciclo de vida	
11. Governança de Dados e Segurança de Dados	
11.1 Cadeia de controle de dados	
12. Governança de Modelos e Risco de Modelos	
12.1 Questões de validação	
13. Modelos Fundamentais e Terceiros	
13.1 Concentração e risco da cadeia de valor	
14. Modelagem de Ameaças à Segurança da IA	
14.1 Método de modelo de ameaças	

15. OWASP Top 10 para Aplicações de LLM em 2025	
15.1 Como um analista utiliza a lista	
16. Segurança de IA Agética	
17. Segurança de Geração Aumentada por Recuperação	
17.1 Controles RAG	
18. Segurança de prompts, interfaces e saídas	
18.1 Exemplos de tratamento de saída	
19. Identidade, Ferramentas, APIs e MCP	
19.1 Segurança MCP	
20. Privacidade, Propriedade Intelectual e Registros	
20.1 Privacidade e avaliação de registros	
20.2 Propriedade intelectual	
21. Equidade, Transparência, Explicabilidade e Supervisão Humana	
21.1 Evite erros comuns	
22. Avaliação, Red Teaming e Aceitação	
22.1 Regras de engajamento da equipe vermelha	
23. Monitoramento, Incidentes, Mudanças e Desativação	
23.1 Resposta a incidentes de IA	
24. Garantia, Evidências, Testes e Métricas	
24.1 Método de teste de controle	
25. Matriz de Controles de IA da CSA v1.1	
25.1 Uso prático	
26. Ferramentas de segurança e garantia de IA de código aberto	
26.1 Garak	
26.2 Promptfoo	
26.3 Giskard	
26.4 PyRIT	
26.5 Inspeccionar IA	
26.6 Caixa de Ferramentas de Robustez Adversarial	
26.7 LLM Guard	
26.8 Presídio	
26.9 Guarda-corpos IA	
26.10 Avaliações OpenAI	
26.11 Langfuse	

26.12 MLflow	
26.13 Evidentemente	
26.14 Verificações profundas	
26.15 ModelScan	
26.16 Gitleaks	
26.17 Trivy	
26.18 MITRE ATLAS	
27. Manual de Governança de IA para Gestores	
27.1 Ritmo operacional	
27.2 Perguntas que os líderes devem responder	
28. Guia de Carreira para Analista Júnior de Risco e Segurança em IA	
28.1 Cargos de nível inicial	
28.2 Trabalho diário	
28.3 Resumo das evidências	
29. Laboratório ficcional, Plano de trinta dias e entrevistas	
29.1 Laboratório de Portfólio	
29.2 Plano de trinta dias	
29.3 O que é o NIST AI RMF?	
29.4 Risco do modelo versus risco do sistema?	
29.5 O que é injeção imediata?	
29.6 Como você avalia um LLM?	
29.7 O que é RAG?	
29.8 Por que a supervisão humana é difícil?	
29.9 O que é um inventário de IA?	
29.10 Como as ferramentas comprovam a conformidade?	
29.11 Como você relata uma descoberta?	
29.12 O que caracteriza um bom analista júnior?	
30. Modelos, Glossário, Índice e Referências	
30.1 Inventário de casos de uso de IA	
30.2 Avaliação do impacto e dos riscos da IA	
30.3 Documento de trabalho de avaliação de IA	
30.4 Registro de incidentes e alterações de IA	
30.5 Glossário	
30.6 Índice de assuntos	

[30.7 Referências oficiais](#)

Guia do Capítulo

Capítulo	Título	Começa na página
1	Fundamentos da IA e Uso Confiável	5
2	Governança, normas e cenário jurídico	6
3	NIST AI RMF Core	7
4	GOVERNAR: Cultura, Responsabilidade e Políticas	8
5	MAPA: Contexto, Pessoas e Impacto	10
6	MEDIDA: Testes e Análise de Riscos	12
7	GERENCIAR: Tratamento, Implantação e Melhoria	13
8	Perfil de IA Generativa do NIST	14
9	ISO/IEC 42001 e ISO/IEC 23894	15
10	Inventário de IA, casos de uso e ciclo de vida	16
11	Governança de dados e segurança de dados	17
12	Governança de Modelos e Risco de Modelos	18
13	Modelos de Fundação e Terceiros	19
14	Modelagem de Ameaças de Segurança por IA	20
15	OWASP Top 10 para candidaturas a LLM em 2025	21
16	Segurança de IA Agencial	22
17	Segurança de Geração Aumentada por Recuperação	23
18	Segurança de prompts, interfaces e saídas	24
19	Identidade, Ferramentas, APIs e MCP	25
20	Privacidade, propriedade intelectual e registros	26
21	Equidade, Transparência, Explicabilidade e Supervisão Humana	27
22	Avaliação, Red Teaming e Aceitação	28
23	Monitoramento, incidentes, mudanças e desativação	29
24	Garantia, Evidências, Testes e Métricas	31
25	Matriz de Controles de IA da CSA v1.1	32
26	Ferramentas de segurança e garantia de IA de código aberto	33
27	Manual de Governança de IA para Gestores	39
28	Guia de Carreira para Analista Júnior de Risco e Segurança em IA	40
29	Laboratório de Ficção, Plano de Trinta Dias e Entrevistas	42
30	Modelos, Glossário, Índice e Referências	45

1. Fundamentos da IA e Uso Confiável

A confiabilidade da IA depende do sistema completo, das pessoas que o compõem, de sua finalidade, dos dados, do modelo, das interfaces, dos controles e dos efeitos no mundo real.



AI risk management follows the system from idea through retirement

Figura 1. Ciclo de vida do sistema de IA

Conceito	Significado literal	Pergunta do analista
sistema de IA	Pessoas, dados, modelos, software, infraestrutura, regras e processos utilizados para um resultado.	Qual é o limite completo?
Aprendizado de máquina	O software aprende padrões a partir dos dados, em vez de apenas regras fixas.	Que dados e métricas sustentam esse comportamento?
IA generativa	Um modelo produz texto, imagens, áudio, vídeo, código ou outros conteúdos.	O que pode ser inventado, vazado ou usado indevidamente?
IA Agética	Um sistema planeja e utiliza ferramentas para atingir objetivos com certo grau de autonomia.	Que autoridade pode exercer?
Confiabilidade	Evidências de que características como validade, segurança, proteção, privacidade, imparcialidade, transparência e responsabilidade são abordadas.	Que alegação, limite, teste e proprietário a sustentam?

1.1 Características confiáveis

- **Válido e confiável:** funciona para o propósito e nas condições definidas.
- **Seguro:** danos físicos, financeiros, legais, emocionais ou operacionais inaceitáveis são prevenidos ou reduzidos.
- **Seguro e resiliente:** resiste a ataques, uso indevido, falhas e interrupções, e pode se recuperar.
- **Responsabilidade e transparência:** decisões, proprietários, limites e evidências podem ser examinados.
- **Explicável e interpretável:** as pessoas recebem razões úteis e adequadas à decisão.
- **Privacidade reforçada e imparcialidade:** os dados e os resultados são tratados de forma lícita e qualquer viés prejudicial é avaliado.

2. Governança, Normas e Cenário Jurídico

A governança interliga estruturas voluntárias, sistemas de gestão, práticas técnicas, contratos e legislação aplicável.

Fonte	Usar	Limite importante
NIST AI RMF 1.0	Estrutura voluntária de risco organizada em Governança, Mapeamento, Medição e Gestão.	Publicado em 2023; o NIST afirma que a revisão está em andamento.
NIST AI 600-1	Perfil de risco e ações da IA generativa	Um perfil, não uma certificação.
ISO/IEC 42001:2023	Requisitos do sistema de gerenciamento de IA	Padrão protegido por direitos autorais; o escopo da certificação é importante.
ISO/IEC 23894:2023	Diretrizes para gerenciamento de riscos de IA	Adapte à organização e ao contexto.
Lei de IA da UE	Deveres legais baseados em risco para funções e usos abrangidos	A aplicação é faseada; os factos e a legislação em vigor determinam o resultado.
OWASP / MITRE ATLAS	Riscos de segurança, técnicas, defesas e ideias para testes	Não é um programa de conformidade total.
CSA AICM v1.1	Mapeamento de objetivos e garantias de controle de IA	Utilize o artefato atual e o escopo aplicável.

2.1 Registro legal e de obrigações

- Identificar jurisdições , setores, clientes, contratos, normas trabalhistas, deveres do consumidor, legislação de privacidade, propriedade intelectual, registros, acessibilidade, discriminação, segurança do produto e requisitos de segurança cibernética.
- Classifique a função organizacional: fornecedor/desenvolvedor, implementador/operador, importador, distribuidor, usuário, controlador/processador de dados ou outra função definida por lei ou contrato.
- Registre o uso exato, as pessoas afetadas, os recursos proibidos ou de alto impacto, o aviso, o consentimento ou outra autorização, a revisão humana, os direitos, os relatórios, a retenção e as obrigações do fornecedor.
- Considere os resumos regulamentares como ferramentas de triagem. Busque aconselhamento qualificado sobre a aplicabilidade e os prazos.

3. Núcleo RMF de IA do NIST

O NIST AI RMF Core utiliza quatro funções interligadas para gerenciar os riscos da IA para pessoas, organizações e sociedade.



NIST AI RMF functions work continuously, not as a one-time checklist

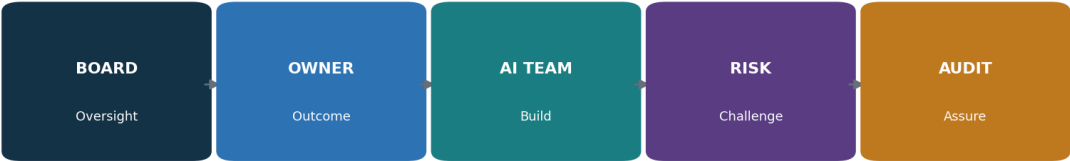
Figura 2. Núcleo RMF de IA do NIST

Função	Propósito	Evidência típica
GOVERNAR	Políticas, funções, cultura, responsabilidade, tolerância ao risco, fornecedores e melhoria contínua.	Estatuto, política, RACI, treinamento, inventário, exceções, atas
MAPA	Objetivo, contexto, pessoas, impactos, dependências e riscos.	Mapeamento do sistema, caso de uso, partes interessadas, avaliação de impacto, modelo de ameaças
MEDIR	Métodos, testes, métricas, incerteza, limitações e revisão independente.	Plano de testes, conjuntos de dados, resultados, nível de confiança, relatório da equipe vermelha, validação.
GERENCIAR	Priorizar, tratar, aceitar, implantar, monitorar, responder e aposentar	Registro de riscos, aprovações, condições, monitoramento, registros de incidentes/alterações/desativação

Não utilize o RMF como uma caixa de seleção: Uma categoria ou subcategoria só se torna útil após ser vinculada a um sistema, risco, ação, evidência, resultado, decisão e data de revisão específicos.

4. GOVERNAR: Cultura, Responsabilidade e Políticas

O GOVERN define quem pode decidir, quais regras se aplicam e como as preocupações chegam aos líderes responsáveis.



Clear decision rights prevent accountability gaps

Figura 3. Funções de governança da IA

4.1 Estrutura de governança

- Conselho ou órgão diretivo: supervisionar o desempenho da gestão e os riscos materiais.
- Patrocinador executivo: define a direção, os recursos, a tolerância ao risco e o processo de escalonamento.
- Proprietário da empresa: propósito próprio, benefício, processo afetado, supervisão humana e resultado.
- Proprietário da IA/modelo: responsável pela seleção, configuração, avaliação, versões e limitações do modelo.
- Proprietário dos dados: autorizar as fontes, a qualidade, o acesso, o uso, a retenção e a exclusão.
- Especialistas em segurança, privacidade, assuntos jurídicos, conformidade, segurança do trabalho, recursos humanos, compras, acessibilidade e domínio específico: analisem seus riscos.
- Risco ou validação independente: questionar as evidências e as decisões em um nível compatível com o impacto.
- Auditoria interna: avaliação independente da governança e das operações de controle, sem se tornar o proprietário.

● Área de política	● Decisão mínima
Uso aceitável	Usos e dados aprovados, restritos e proibidos
Classificação de risco	Fatores de impacto, limites, revisões necessárias e autoridade.
Desenvolvimento/aquisição	Ciclo de vida seguro, evidências do fornecedor, testes, aprovação e alterações.

● Área de política	● Decisão mínima
Supervisão humana	Competência, autoridade, carga de trabalho, informações, poder de decisão e escalonamento do revisor.
Exceções	Risco, controles compensatórios, aprovador, expiração, monitoramento e encerramento.
Preocupações	Denúncia, não retaliação, investigação, proteção e relato.

5. MAPA: Contexto, Pessoas e Impacto

O MAP transforma a descrição de um modelo em uma imagem compreensível de propósito, pessoas, contexto e impacto.



Assess the complete sociotechnical system—not only the model

Figura 4. Mapa completo do sistema de IA

5.1 Registro de contexto

- Necessidade comercial, benefício pretendido, medida de sucesso, proprietário, usuários e usos proibidos.
- Pessoas e comunidades afetadas, incluindo pessoas que podem nunca interagir diretamente com o sistema.
- Decisão ou conteúdo produzido, grau de automação, consequências, alternativas, contestabilidade e autoridade humana.
- Fontes de dados, linhagem, direitos, representatividade, atributos sensíveis, proxies e qualidade.
- Modelo, provedor, versão, configuração, solicitações, recuperação, ajuste fino, ferramentas, integrações, infraestrutura e dependências.
- Condições de implantação, geografia, idioma, acessibilidade, cultura, urgência, escala e uso indevido razoavelmente previsível.
- Modos de falha, agentes de ameaça, danos, benefícios, incertezas, controles existentes e monitoramento.

Fator de impacto	Exemplo de menor preocupação	Exemplo de maior preocupação
Decisão	Redação de texto interno	Elegibilidade, emprego, crédito, cuidados, segurança ou decisão legal
Pessoas	Equipe treinada com revisão	Público em geral ou pessoas vulneráveis com opções limitadas
Autonomia	Sugestão apenas	Atua por meio de contas, dinheiro, sistemas ou dispositivos físicos.
Escala	Pequeno piloto reversível	Efeito grande, persistente e difícil de reverter.
Dados	Sintético ou público	Dados sensíveis, biométricos, confidenciais ou de crianças
Transparência	Claramente divulgado e contestável	Uso oculto ou apelo fraco

Fator de impacto	Exemplo de menor preocupação	Exemplo de maior preocupação
Falha	Pequeno inconveniente	danos materiais financeiros, à saúde, aos direitos, à segurança ou à integridade

6. MEDIR: Testes e Análise de Riscos

O MEASURE gera evidências confiáveis sobre desempenho, danos, uso indevido, segurança, privacidade e incerteza.

6.1 Plano de medição

- Traduza cada risco importante em uma afirmação testável e em um limite de aceitação antes de ver o resultado.
- Utilize dados de avaliação representativos, protegidos e versionados, com proveniência documentada, exclusões e lacunas conhecidas.
- Teste os casos normais, extremos, de subgrupo, multilíngues, de acessibilidade, adversários, de alto impacto e de falha segura.
- Separe os dados de desenvolvimento, validação e aceitação final sempre que possível para reduzir o sobreajuste.
- Meça tanto os benefícios quanto os malefícios; as médias podem ocultar falhas graves em um subgrupo ou eventos raros.
- Registre o modelo/versão do sistema, o prompt, as ferramentas, os dados, o ambiente, o avaliador, a rubrica humana, a amostra, a aleatoriedade, o custo, o resultado, a confiança e as limitações.
- Utilize revisão independente quando o impacto, a incerteza, o conflito de interesses ou a dependência externa forem elevados.

Medir	Pergunta	Exemplo de evidência
Qualidade da tarefa	Executa a tarefa pretendida?	Precisão, fundamentação, gravidade do erro, avaliação humana
Segurança	Isso evita danos inaceitáveis?	Testes de cenário, recusas, escalonamento, análise de riscos
Segurança	Um atacante pode manipular ou extrair valor?	Modelo de ameaças, testes de injeção, testes de abuso de ferramentas, relatório de equipe vermelha
Equidade	Os erros ou os tratamentos diferem de forma significativa?	Resultados de subgrupos, revisão interseccional, análise causal/contextual
Privacidade	Os dados podem ser expostos, inferidos, retidos ou utilizados indevidamente?	DPIA, testes de vazamento, evidências de acesso/retenção/exclusão
Resiliência	Ele falha de forma segura durante mudanças ou interrupções?	Testes de carga, deriva, dependência, reversão e recuperação

7. GERENCIAR: Tratamento, Implantação e Melhoria

O MANAGE transforma o risco mensurado em uma decisão tomada de responsabilidade, um tratamento, condições de implementação, monitoramento e melhoria.

Tratamento	Quando útil	Registro obrigatório
Evitar	O uso é proibido ou o risco não pode ser justificado.	Decisão, âmbito afetado, alternativas, aplicação da lei
Reduzir	Os controles podem diminuir a probabilidade ou o impacto.	Controle, proprietário, data de vencimento, risco residual, teste
Transferir/compartilhar	O contrato ou seguro aloca parte das consequências.	Alocação exata, exclusões, dependência, risco remanescente
Aceitar	O risco residual está dentro da autoridade e do apetite.	Justificativa, evidências, aprovador, condições, validade, monitoramento
Piloto	A incerteza pode ser reduzida com segurança.	Pessoas/dados/autoridade/tempo limitados, regra de parada, medição, saída

7.1 Portal de implantação

- As revisões necessárias foram concluídas e as pendências não resolvidas estão dentro da tolerância autorizada.
- Os limiares de aceitação são atingidos no sistema completo semelhante ao de produção, e não apenas no modelo base.
- Os usuários compreendem a finalidade, os limites, os usos proibidos, as obrigações de verificação e os procedimentos de escalonamento.
- Os revisores humanos têm tempo, habilidade, informação, autoridade e um poder de decisão que pode ser utilizado.
- Os controles de segurança, privacidade, fornecedores, registro de eventos, incidentes, continuidade, reversão, registros e exclusão estão prontos.
- O monitoramento possui proprietários, limites, alertas, planos de resposta, gatilhos de mudança e critérios de desativação.

8. Perfil de IA Generativa do NIST

O documento NIST AI 600-1 adapta o RMF de IA aos riscos que são especialmente importantes para a IA generativa.

Tema de risco	Significado prático	Exemplo de tratamento
Confabulação	Um resultado plausível pode ser falso.	Fundamentação, citações, verificação, incerteza, uso limitado de decisões
Conteúdo perigoso ou odioso	Os resultados podem facilitar danos ou abusos.	Limites de uso, classificadores, política, revisão, monitoramento, relatórios
Privacidade de dados	Informações sensíveis podem entrar ou sair do sistema.	Minimização, redação, acesso, retenção, exclusão, testes de vazamento
Integridade da informação	Conteúdo sintético pode enganar ou distorcer os ecossistemas.	Divulgação, proveniência, verificação, limites de taxa, resposta
Segurança da informação	Os atacantes podem injetar, roubar, evadir ou explorar.	Modelagem de ameaças, isolamento, privilégio mínimo, tratamento seguro de saída.
Propriedade intelectual	Treinamento, entrada ou saída podem gerar problemas de direitos.	Proveniência, termos, licenças, revisão, registros, processo de disputa
Impactos ambientais	Treinamento e uso consomem recursos	Medir energia/calcular onde o material; definir a eficiência e usar controles
Configuração humano-IA	O viés de automação ou a dependência emocional podem causar danos.	Design de interface, alfabetização, revisão humana, escalonamento, salvaguardas de bem-estar
Cadeia de valor	O risco se propaga por meio de dados, modelos, plataformas, integradores e usuários.	Mapeamento de fornecedores, contratos, evidências, aviso de alteração, incidentes compartilhados

Uso do perfil: Selecione os riscos e ações relevantes para o caso de uso específico. Não afirme que todos os riscos da IA generativa estão resolvidos apenas porque um provedor de uso geral oferece medidas de segurança.

9. ISO/IEC 42001 e ISO/IEC 23894

A norma ISO/IEC 42001 fornece um sistema de gestão de IA; a norma ISO/IEC 23894 fornece orientações para a gestão de riscos de IA.

Elemento do sistema de gestão	Resultado prático
Contexto	Partes interessadas, obrigações, âmbito da IA, processos, dependências
Liderança	Política, responsabilidade, funções, recursos, gestão de riscos
Planejamento	Riscos, oportunidades, objetivos, ações, planejamento de mudanças
Apoiar	Competência, consciência, comunicação, informação documentada
Operação	Processo de risco de IA, avaliação de impacto, controles de ciclo de vida, fornecedores
Avaliação de desempenho	Monitoramento, medição, auditoria interna, análise da gestão.
Melhoria	Não conformidade, ação corretiva, melhoria contínua

9.1 Certificação e precauções relativas a direitos autorais

- Utilize uma cópia autorizada das normas ISO; este manual não reproduz seus requisitos ou texto de controle.
- Defina com precisão o escopo do sistema de gestão de IA: organização, produtos, serviços, locais, tecnologias e exclusões.
- Um certificado comprova apenas a existência da organização, o escopo, o padrão, as datas e o status da certificação especificados.
- A certificação não comprova que todos os resultados da IA sejam precisos, justos, seguros, legais ou confiáveis.
- Mapeie os processos existentes de segurança, privacidade, qualidade, risco, fornecedores e auditoria para evitar a duplicação de documentação.

10. Inventário de IA, casos de uso e ciclo de vida

Um inventário preciso e um ciclo de vida controlado são a base da governança.



A use-case gate matches oversight and evidence to risk

Figura 5. Caso de uso de IA

Campo de inventário	O que gravar
Identidade	Nome do sistema/caso de uso, ID, proprietário, patrocinador, equipe, status
Propósito	Uso pretendido, usuários, pessoas afetadas, decisões, benefícios, uso proibido
Tecnologia	Modelo/provedor/versão, prompts, RAG, agentes, ferramentas, APIs, hospedagem
Dados	Fontes, proprietários, sensibilidade, direitos, localização, retenção, uso de treinamento
Impacto	Nível de risco, danos, leis, contratos, avaliações, supervisão humana
Evidências	Avaliação, segurança, privacidade, fornecedor, acessibilidade, aprovação
Operações	Monitoramento, incidentes, mudanças, dependências, recuperação, desativação

10.1 Controles do ciclo de vida

- Inclusão e triagem antes da aquisição, experimentação com dados reais ou uso público.
- Elaborar mapas de sistemas e dados, avaliações de impacto e ameaças, requisitos, limites de aceitação e reversão.
- Construir com controle de versão, ambientes protegidos, componentes aprovados, linhagem, testes e revisão.
- Validar o sistema completo de forma suficientemente independente para avaliar seu impacto e incerteza.
- Aprovar com condições registradas; implementar por meio do controle de alterações; treinar usuários e revisores.
- Monitorar qualidade, segurança, proteção, privacidade, imparcialidade, custo, uso, fornecedores e incidentes.
- Reavaliar alterações substanciais; desativar com segurança o acesso, as integrações, os dados, os artefatos, as contas e os registros.

11. Governança de Dados e Segurança de Dados

Os controles de dados determinam o que um sistema de IA pode aprender, expor, reproduzir ou enfatizar injustamente.

11.1 Cadeia de controle de dados

- Finalidade e autoridade: por que cada fonte é necessária e quais direitos, avisos, permissões ou licenças permitem seu uso.
- Proveniência e linhagem: fonte, método de coleta, data, versão, transformações, rótulos, filtros e usos subsequentes.
- Qualidade e representatividade: completude, precisão, atualidade, duplicatas, desequilíbrio, erros de rotulagem, viés histórico e populações relevantes.
- Segurança: classificação, privilégio mínimo, separação, criptografia, segredos, transferência segura, monitoramento, backup e exclusão.
- Privacidade: minimização, pseudonimização/desidentificação, risco de reidentificação, direitos do titular dos dados, retenção, transferência e técnicas de aprimoramento da privacidade.
- Defesa contra envenenamento: fontes confiáveis, controles de colaboradores, validação, revisão de anomalias, conjuntos de dados assinados/versionados, quarentena e reversão.
- Proteção da avaliação: evita o vazamento do conjunto de testes e preserva um conjunto de aceitação final controlado.

Evidências	Detalhes mínimos
Cartão de conjunto de dados	Finalidade, fonte, pessoas/populações, coleção, campos, rótulos, exclusões, limites, licença
Registro de linhagem	Transformações de código-fonte para funcionalidade, código/versão, proprietário, aprovações, datas
Relatório de qualidade	Regras, população, exceções, análise de subgrupos, correções, limitações
Acessar relatório	Usuários/serviços, funções, concessões, revisões, remoções, atividade privilegiada
Teste de exclusão	Solicitação, sistemas/cópias/índices/backups, método, resultado, limites residuais

12. Governança de Modelos e Risco de Modelos

Controles de governança de modelos: seleção, documentação, validação, alteração, implementação e desativação.

Artefato	Propósito
Placa modelo/do sistema	Uso pretendido, uso proibido, arquitetura, dados, desempenho, limitações, ética/segurança/proteção
Registro de versão	Modelo, pesos, versão do provedor, configuração, prompt, adaptadores, ferramentas, código, ambiente
Relatório de validação	Independência, métodos, dados, limiares, resultados, falhas, limitações, decisão
Nível de risco	Fatores de impacto, revisões necessárias, autoridade de decisão, monitoramento
Alterar registro	Motivo, componentes afetados, escopo da regressão, aprovação, implementação, reversão
Registro de aposentadoria	Substituição, usuários, integrações, acesso, artefatos, dados, retenção, exclusão, tarefas residuais

12.1 Questões de validação

- O uso está dentro das condições demonstradas e aprovadas pelo modelo?
- Os dados e as populações de avaliação são relevantes para a produção?
- Os limites estão vinculados a prejuízos comerciais em vez de apenas a médias técnicas?
- A aplicação completa adiciona avisos, recursos de recuperação, ferramentas, pós-processamento ou comportamento humano que alteram o risco?
- As incertezas e limitações são visíveis para os tomadores de decisão e usuários?
- É possível restaurar uma versão anterior e rastrear decisões dependentes até a versão ativa?

13. Modelos de Fundação e Terceiros

Um provedor de modelo de fundação fornece uma camada; a organização que a implementa ainda detém a propriedade de seu uso, integrações, dados e efeitos.

Comprovante do fornecedor	Questão de revisão
Documentação do sistema/modelo	Modelo/versão exatos, uso pretendido/proibido, capacidades, limitações, avaliação
Garantia de segurança	Escopo, período, testes, vulnerabilidades, processo de incidentes, isolamento de inquilinos
Termos de dados	Uso de prompts/uploads/saídas/logs/feedback, treinamento, retenção, exclusão, localização e subprocessadores.
Gestão de mudanças	Aviso, fixação de versão, descontinuação, evidência de regressão, reversão
Disponibilidade/resiliência	Dependências, limites, suporte, recuperação, continuidade, exportação
Questões legais/Propriedade intelectual	Funções, licenças, indenização, restrições, transparência, suporte regulatório
Auditoria/evidência	Relatórios, registros, configuração do cliente, acesso, incidentes e evidências de exclusão
Saída	Exportação de dados/modelo/configuração, migração, encerramento de conta, exclusão verificada

13.1 Risco de concentração e da cadeia de valor

- Modelo de mapa, nuvem, dados, rotulagem, incorporações, banco de dados vetorial, orquestração, ferramentas, moderação de conteúdo, monitoramento e fornecedores de serviços humanos.
- Identificar dependências comuns que podem falhar ou mudar em conjunto.
- Testar a responsabilidade contratual em relação à arquitetura técnica.
- Manter alternativas ou uma paralisação controlada sempre que o impacto nos negócios o justificar.
- Reavaliar alterações de fornecedores, novos termos de treinamento, desativação de modelos, aquisições, incidentes, sanções e alterações de subcontratados.

14. Modelagem de Ameaças à Segurança da IA

A modelagem de ameaças identifica ativos, limites de confiança, atacantes, caminhos de abuso, controles, detecções e recuperação segura.

14.1 Método de modelagem de ameaças

- Desenhe usuários, administradores, serviços, endpoints de modelo, armazenamentos de dados, índices, prompts, ferramentas, redes, logs, provedores e revisores humanos.
- Marque os seguintes ativos: dados sensíveis, pesos do modelo, avisos do sistema, credenciais, decisões, dinheiro, contas, reputação e segurança.
- Defina os limites de confiança e todos os locais onde conteúdo não confiável pode se tornar instruções ou ações.
- Descreva os agentes da ameaça, o acesso, os objetivos, as condições prévias, o caminho do ataque, o impacto nos negócios, as evidências e a recuperação.
- Mapeie as técnicas relevantes do MITRE ATLAS e do OWASP, mas adicione o uso indevido específico do domínio e as ameaças comuns a aplicativos.
- Selecione controles preventivos, de detecção, de resposta e de recuperação; teste combinações e alternativas.
- Atualização após alteração de modelo, dados, prompt, ferramenta, provedor, permissão, interface ou uso.

Superfície de ameaça	Exemplos
Entrada	Injeção direta de prompts, arquivos maliciosos, texto oculto, instruções em imagem/áudio
Contexto	Documentos RAG corrompidos, recuperação de dados entre inquilinos, fontes obsoletas ou não autorizadas.
Modelo	Extração, inversão, evasão, envenenamento, capacidade insegura, negação de serviço
Saída	XSS, injeção de SQL/comandos, código inseguro, conselhos prejudiciais, alegações falsas
Ferramentas/agentes	Abuso de privilégios, delegado confuso, fraude em transações, loops, movimentação lateral
Operações	Logs fracos, uso oculto, chaves vazadas, atualizações inseguras, reversão de incidentes deficiente.

15. OWASP Top 10 para Candidaturas a Mestrado em Direito (LLM) em 2025

A lista OWASP 2025 é um ponto de partida prático para a segurança de aplicações de IA generativa.

ID / risco	O que pode acontecer	Proteções essenciais
LLM01 — Injeção Imediata	Instruções não confiáveis alteram o comportamento do modelo ou alcançam ferramentas conectadas.	Zonas de confiança separadas; ferramentas de restrição; contexto de filtragem; validação de ações; teste de injeção direta e indireta.
LLM02 — Divulgação de Informações Confidenciais	Solicitações, saídas, registros, dados de treinamento ou conectores revelam informações protegidas.	Minimizar dados; classificar; redigir; controlar o acesso; definir o período de retenção; testar vazamentos; monitorar.
LLM03 — Cadeia de Suprimentos	Modelos, dados, pacotes, adaptadores, serviços ou artefatos estão comprometidos ou não são confiáveis.	Aprovar fontes; verificar procedência, assinaturas, hashes, licenças, vulnerabilidades e avisos de alteração.
LLM04 — Envenenamento de Dados e Modelos	Dados ou componentes de modelo manipulados criam comportamentos ocultos ou inseguros.	Proteger a linhagem; validar as fontes; isolar as contribuições; executar testes de anomalia e comportamentais.
LLM05 — Manipulação inadequada de resultados	Os sistemas subsequentes confiam na saída do modelo como código, conteúdo ou comandos seguros.	Tratar a saída como não confiável; validar, codificar, parametrizar, isolar em sandbox e autorizar.
LLM06 — Agência Excessiva	Um sistema de IA possui mais ferramentas, permissões, autonomia ou tempo do que o necessário.	Privilegio mínimo; ferramentas limitadas; limites; aprovações; fronteiras de transação; mecanismo de desativação; auditoria.
LLM07 — Vazamento de prompts do sistema	Instruções ocultas ou segredos são expostos ou utilizados como uma barreira de segurança.	Mantenha segredos fora dos avisos; aplique controles externamente; teste vazamentos; limite o contexto sensível.
LLM08 — Fraquezas de Vetores e Incorporação	Índices ou incorporações permitem recuperação, adulteração, mistura ou inferência não autorizadas.	Isolamento de inquilinos; ACLs de origem; filtragem de metadados; revisão de ingestão; testes de recuperação; exclusão.
LLM09 — Desinformação	Resultados confiantes, porém incorretos, podem levar a decisões ou ações prejudiciais.	Fundamentar as alegações; citar as fontes; definir a incerteza; revisão humana; avaliação factual; falha segura.
LLM10 — Consumo Ilimitado	Entradas, loops, saídas ou chamadas de ferramentas consomem recursos financeiros, computacionais ou de serviço.	Limites de taxa, token, tempo, recursão, gasto e concorrência; alertas; quotas; disjuntores.

15.1 Como um analista utiliza a lista

- Confirme a versão e a arquitetura do aplicativo; o modelo base por si só não é o objetivo da avaliação.
- Mapeie cada risco aplicável aos componentes, cenários de ameaça, controles, evidências, casos de teste, responsável e risco residual.
- Teste os controles em conjunto: os filtros podem ser ignorados e o comportamento do modelo é probabilístico.
- Validar falhas seguras, mensagens ao usuário, detecção, resposta, reversão e reteste.
- Não rotule um aplicativo como "compatível com OWASP"; o OWASP Top 10 é um guia de conscientização e testes, não um padrão de certificação.

16. Segurança de IA Agética

Sistemas agéticos adicionam planejamento, memória, seleção de ferramentas, delegação, persistência e autoridade no mundo real.



Agent safety depends on constrained authority and verified actions

Figura 6. Loop de ação do agente restrito

Tema de risco agêntico	Exemplo	Controlar
Manipulação de objetivos	Conteúdo não confiável altera o objetivo	Canal de destino confiável, hierarquia de instruções, separação de contexto, confirmação
Uso indevido de ferramentas	Agente acessa e-mail, código, pagamento, administração ou ferramenta de banco de dados de forma insegura.	Lista de permissões, esquemas, identidade restrita, aplicação de políticas, sandbox
Autonomia excessiva	O agente age sem uma revisão significativa.	Aprovações baseadas em risco, pré-visualização de transações, controle por duas pessoas, botão de parada
Envenenamento da memória	Conteúdo ruim persiste e influencia trabalhos futuros.	Confiança da fonte, memória com escopo, validação, expiração, revisão, exclusão
Confiança entre agentes	Um agente considera a produção de outro como autoridade.	Identidade mútua, proveniência, contratos, validação, privilégio mínimo
Comportamento descontrolado	Os loops consomem tempo, dinheiro, chamadas ou causam efeitos repetidos.	Limites de etapas/tempo/custo, idempotência, controle de taxas, disjuntor
Lacuna de responsabilização	Ninguém detém a propriedade de uma cadeia de decisões automatizadas.	Proprietário, rastreamento, recebimento da ação, escalonamento, reversão, revisão do incidente

Fonte atual: A OWASP publicou sua lista Top 10 de vulnerabilidades para aplicações agentes em 2026, revisada por pares, em 9 de dezembro de 2025. Consulte o documento oficial para obter os nomes e detalhes exatos dos riscos; aplique-o à segurança de aplicações, identidades, APIs, dados e transações em geral.

17. Segurança de Geração Aumentada por Recuperação

O RAG pode melhorar a fundamentação, mas aumenta os riscos de ingestão, indexação, recuperação, autorização, citação e exclusão.



RAG adds trust boundaries at ingestion, storage, retrieval, and generation

Figura 7. Limites de confiança RAG

17.1 Controles RAG

- Aprovar fontes, proprietários, direitos, frescor, sensibilidade, usuários autorizados e método de ingestão.
- Analisar arquivos e conteúdo; detectar instruções ocultas; colocar em quarentena e revisar contribuições não confiáveis.
- Preservar a identidade da fonte, o locatário, a classificação, a ACL, a versão, a data e o status de exclusão nos metadados.
- Exija autorização antes da recuperação e novamente antes da exibição; não confie apenas na similaridade.
- Inquilinos e domínios de segurança separados para armazenamento, chaves, índices, cache, logs e avaliação.
- Envenenamento de testes, injeção indireta, recuperação não autorizada, vazamento entre inquilinos, conteúdo desatualizado, precisão de citação e exclusão.
- Exija respostas que demonstrem citações úteis e incertezas; verifique afirmações de alto impacto com base em fontes confiáveis.
- Propagar a exclusão/correção da origem para blocos, vetores, caches, armazenamentos derivados e conjuntos de dados de monitoramento.

18. Segurança de prompts, interfaces e saídas

Os prompts e as saídas são dados da aplicação, não limites de controle confiáveis.

Camada	Exemplos de controle
Interface do usuário	Finalidade, aviso, uso proibido, obrigação de verificação, exemplos seguros, feedback, apelação
Entrada	Limites de tamanho/tipo, verificação de malware, normalização de codificação, classificação, redação, detecção de abuso.
Instruções	Modelos versionados, separação de dados/instruções, segredos mínimos, aprovação, testes
Chamada de modelo	Modelo/versão aprovados, parâmetros, limites de tempo/token/taxa, credenciais protegidas
Saída	Esquema, lista de permissões, codificação, parametrização, citação, revisão de segurança, confiança/incerteza
Uso a jusante	Tratar como não confiável; aprovação humana ou por política; ambiente de teste; validação de transação; reversão
Registros	Rastrear IDs e decisões com minimização, acesso, retenção, integridade e privacidade.

18.1 Exemplos de tratamento de saída

- Nunca insira a saída do modelo diretamente em um shell, consulta SQL, DOM do navegador, modelo, política de acesso ou caminho de código de produção sem validação específica para a finalidade.
- Utilize esquemas estruturados, mas ainda assim valide tipos, cumprimentos, valores, autorizações e regras de negócio fora do modelo.
- Separe a geração de conteúdo da permissão para agir. Uma resposta fluente não é prova de autoridade ou veracidade.
- Projetar estados de recusa e erro que não revelem segredos e que direcionem os usuários para alternativas seguras.

19. Identidade, Ferramentas, APIs e MCP

Os controles de identidade e de ferramentas determinam a diferença entre uma sugestão de IA e um evento causado por IA.

Controlar	Questão de implementação
Identidade humana	O usuário possui autenticação forte e está autorizado a acessar os dados e realizar a ação solicitada?
Identidade da carga de trabalho	Cada agente/serviço possui uma identidade única, de curta duração e com escopo restrito?
Delegação	O sistema consegue comprovar quem delegou qual autoridade, para qual recurso, finalidade e período?
Lista de permissões de ferramentas	Ferramentas, métodos, parâmetros, destinos e classes de dados são explicitamente permitidos?
Controle de transação	Os limites de quantidade, volume, destinatário, ambiente e ação irreversível são impostos fora do modelo?
Aprovação	O avaliador consegue visualizar a ação proposta em detalhes, o contexto material, os riscos e as mudanças necessárias?
Auditoria	É possível reconstruir cada objetivo, contexto, decisão do modelo, chamada de ferramenta, aprovação, resultado e reversão?

19.1 Segurança MCP

- O Model Context Protocol (MCP) conecta aplicações de IA a ferramentas e dados por meio de interfaces padronizadas; ele não torna um servidor ou ferramenta confiável.
- Inventariar servidores, proprietários, código/fonte, transporte, autenticação, permissões, ferramentas, esquemas, dados, destinos de rede, logs e caminho de atualização.
- Utilize registros aprovados, pacotes verificados, versões fixadas, execução restrita, controles de saída, isolamento de segredos e credenciais com privilégios mínimos.
- Considere as descrições das ferramentas, os recursos, os avisos e o conteúdo retornado como potencialmente não confiáveis e capazes de influenciar o modelo.
- Exija autorização no serviço de dados/ação propriamente dito, e não apenas na camada conversacional.
- Teste comportamentos maliciosos do servidor, confusão de nomes de ferramentas, injeção de parâmetros, fluxo de dados entre servidores, permissões excessivas e atualizações inseguras.

20. Privacidade, Propriedade Intelectual e Registros

Os fluxos de dados da IA levantam questões sobre privacidade, confidencialidade, propriedade intelectual, manutenção de registros e divulgação.

20.1 Avaliação da privacidade e dos registros

- Identificar pessoas, categorias de dados, nível de sensibilidade, fonte, finalidade, autoridade/base legal, avisos, opções, direitos e grupos vulneráveis.
- Solicitações de mapas, uploads, saídas, incorporações, ajustes finos, registros, feedback, revisão humana, uso em treinamento, provedores, subprocessadores, locais e transferências.
- Minimize a coleta e o contexto; utilize redação, pseudonimização, recuperação privada, processamento local ou dados sintéticos quando apropriado.
- Defina a retenção e a exclusão por tipo de dados e cópia do sistema; teste os direitos e a exclusão por meio de provedores, índices, registros, backups e dados derivados.
- Avaliar memorização, inferência, reidentificação, previsão de atributos, inferência de associação e vazamento entre usuários.
- Preserve os registros necessários para decisões, notificações, consentimentos/autorizações, versões, aprovações, incidentes, disputas e prestação de contas, sem precisar guardar tudo para sempre.

20.2 Propriedade intelectual

- Confirme os direitos e licenças para treinamento, ajuste, avaliação, recuperação, instruções, mídia, código e resultados.
- Analise os termos do fornecedor referentes à propriedade, uso para treinamento, confidencialidade, indenização, restrições e opções de exclusão.
- Utilize informações sobre a origem e as credenciais de conteúdo quando apropriado; mantenha as citações das fontes e os registros de contribuição humana.
- Analise os resultados de alto risco em busca de material protegido por direitos autorais, marcas registradas, informações confidenciais, obrigações de licença de código aberto e direitos de publicidade/personalidade.
- Questões legais mais complexas; ferramentas de similaridade técnica não determinam infrações.

21. Equidade, Transparência, Explicabilidade e Supervisão Humana

O uso responsável exige a análise de impactos desiguais, explicações significativas e autoridade humana real.

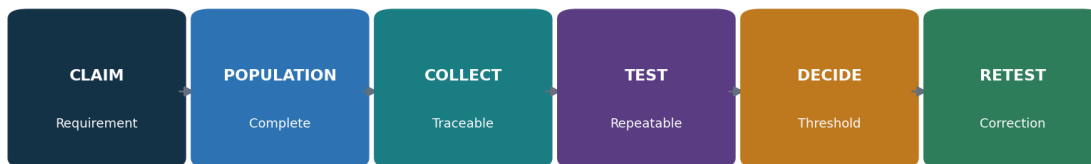
Tópico	Teste prático
Equidade	Defina os danos e grupos relevantes; compare taxas e gravidade; examine causas, indicadores, histórico e alternativas.
Transparência	Informe às pessoas certas que a IA é usada, seu propósito, papel, limitações, dados e como obter ajuda.
Explicabilidade	Forneça razões úteis para a pessoa afetada, operador, revisor, auditor ou desenvolvedor.
Supervisão humana	Tempo do revisor de testes, competência, informação, independência, autoridade, sobreposição e escalonamento.
Contestabilidade	Disponibilize um meio prático para questionar, corrigir, recorrer e obter revisão humana.
Acessibilidade	Testar idiomas, deficiências, alfabetização, dispositivos e tecnologia assistiva no fluxo de trabalho real.

21.1 Evite erros comuns

- Uma métrica de justiça não é uma conclusão moral ou legal; diferentes tipos de danos podem exigir medidas diferentes.
- Remover um atributo protegido não remove proxies ou padrões históricos.
- Uma explicação tecnicamente detalhada, mas inutilizável para a pessoa afetada, não tem sentido.
- Um clique humano não constitui um descuido se o revisor não conseguir detectar o erro, estiver sobrecarregado ou não puder discordar.
- Documentar as compensações, as vozes afetadas, as alternativas rejeitadas, a incerteza residual e a autoridade de decisão.

22. Avaliação, Red Teaming e Aceitação

A avaliação comprova afirmações definidas somente quando o sistema, os dados, os métodos, os limites e as limitações são rastreáveis.



Assurance joins governance claims to reproducible evidence

Figura 8. Cadeia de avaliação e evidências

Tipo de teste	Exemplos
Funcional	Conclusão da tarefa, precisão, relevância, fundamentação, citação, formato
Segurança	Conteúdo prejudicial, conselhos inseguros, escalada da situação, recusa, usuários vulneráveis
Segurança	Injeção, extração, envenenamento, uso indevido de ferramentas, injeção de efluentes, recusa de serviço
Privacidade	Vazamento de informações pessoais identificáveis, memorização, inferência, recuperação não autorizada, exclusão.
Equidade/acessibilidade	Erros de subgrupo, idioma/dialeto, deficiência, efeitos de proxy, usabilidade
Robustez	Ruído, paráfrase, entrada adversária, contexto longo, falha de dependência, deriva
Operacional	Latência, capacidade, limites de taxa/custo, monitoramento, failover, rollback, resposta a incidentes

22.1 Regras de engajamento da equipe vermelha

- Autorização por escrito, alvo especificado, ambiente, tempo, pessoas, ações proibidas, dados, orçamento, taxa e condições de parada.
- Dados de teste sintéticos ou aprovados; sem conteúdo prejudicial não controlado, segmentação de pessoas reais, varredura pública ou testes de terceiros.
- Armazenamento seguro para prompts, resultados, vulnerabilidades, credenciais e informações pessoais.
- Caminho imediato para complicações graves, exposição acidental, instabilidade do sistema ou problemas de segurança.
- Reprodução, justificativa da gravidade, proprietário, correção, teste de regressão e evidências de encerramento.

23. Monitoramento, Incidentes, Mudanças e Desativação

O risco associado à IA muda quando os dados, os modelos, os estímulos, as ferramentas, os usuários, os fornecedores ou o mundo exterior se alteram.



Monitoring must lead to human decisions and controlled change

Figura 9. Ciclo de monitoramento e incidentes

Sinal	Exemplo de gatilho de resposta
Qualidade	A taxa de erros graves ou a confiabilidade fica abaixo do limite aprovado.
Segurança	Saída prejudicial confirmada, desvio de recusa ou quase acidente de alto impacto
Segurança	Injeção bem-sucedida, chamada de ferramenta não autorizada, vazamento, abuso ou evento de credencial
Equidade	Mudança no subgrupo de materiais, padrão de queixas ou população recém-afetada
Privacidade	Retenção inesperada, divulgação, inferência, falha de direitos ou alteração de uso pelo provedor
Operações	Aumento repentino de custo/latência, interrupção de dependência, loop descontrolado, falha de capacidade
Mudar	Novo modelo, aviso, dados, ferramenta, permissão, provedor, geografia, uso ou lei

23.1 Resposta a incidentes de IA

- Detectar e preservar prompts, contexto, recuperação, modelo/versão, configuração, ferramentas, identidades, aprovações, saídas, ações subsequentes e registros.
- Proteja primeiro as pessoas afetadas; interrompa ou limite o sistema, as ferramentas, os dados, os usuários, as transações ou as saídas sob a autoridade aprovada.
- Analise toda a cadeia e identifique decisões ou conteúdos repetidos que necessitem de correção, notificação, reversão ou revisão humana.
- Coordenar as áreas de segurança, proteção, privacidade, assuntos jurídicos, comunicações, provedores, negócios e resposta a incidentes no domínio.
- Corrija usando versões confiáveis; execute testes de regressão; implemente gradualmente; observe a recorrência.
- Registrar lições aprendidas, prestar contas, buscar reparação, controlar mudanças, reaprovar riscos e divulgar informações exigidas por lei ou contrato.

24. Garantia, Evidências, Testes e Métricas

A garantia da qualidade conecta um requisito a um escopo completo, evidências confiáveis, um teste repetível, uma conclusão e a realização de novos testes.

24.1 Método de teste de controle

- Indique o critério exato, a origem/versão, o sistema/uso/versão, o período, o proprietário, o risco e o comportamento esperado.
- Identificar populações completas: casos de uso, modelos, usuários, decisões, avisos, ferramentas, incidentes, mudanças, fornecedores ou casos de avaliação.
- Conciliar o inventário com fontes independentes, como faturamento de API, código, registro de modelos, identidade, compras, rede ou logs.
- Coletar informações como origem, consulta, data, permissões, configuração, hash/versão, amostra e cadeia de custódia; minimizar evidências sensíveis.
- Testar o projeto e a operação; reproduzir resultados automatizados; validar exceções e desvios de controle.
- Anote a condição, as evidências, a população, o risco, a causa, a ação, o proprietário, a data, a proteção provisória e o reteste.

Métrica	Exemplo de definição
Propriedade do estoque	Sistemas de IA ativos com proprietário aprovado + sistemas de IA ativos
Cobertura da avaliação	Sistemas abrangidos com avaliação atual de impacto/ameaça/privacidade + sistemas abrangidos
Avaliação aprovada	Casos necessários que atendem aos limites aprovados + casos necessários, com visualizações de gravidade e subgrupo.
Controle humano	Decisões elegíveis revisadas/revogadas/escaladas com resultados e carga de trabalho do revisor
Exposição à segurança	Resultados de segurança da OpenAI por gravidade, alcance, idade, proprietário e exceção.
Desempenho em incidentes	Deteção, contenção, correção, reparação, recorrência e ações atrasadas
Garantia do fornecedor	Fornecedores críticos de IA com revisão de escopo atual e lacunas de material preenchidas + fornecedores críticos

Atenção ao painel de controle: Uma porcentagem verde pode ocultar sistemas ausentes, testes inadequados, falhas graves raras, grupos excluídos, evidências desatualizadas ou risco aceito. Sempre mostre a população, a fonte, o período, o limite, as exceções, a incerteza e a ação.

25. Matriz de Controles de IA da CSA v1.1

O CSA AICM v1.1 fornece uma matriz de controle atualizada para governança, segurança, privacidade, operações e garantia de IA.

25.1 Uso prático

- Baixe o artefato oficial atual do AICM v1.1 e registre sua versão, licença e quaisquer orientações de implementação utilizadas.
- Defina a organização, o serviço de IA, o estágio do ciclo de vida, o papel do fornecedor/cliente, a tecnologia, os dados, a geografia e o limite de controle.
- Adapte a aplicabilidade em vez de marcar todos os objetivos como "sim"; apresente a justificativa para os itens "não aplicáveis".
- Mapeie cada objetivo relevante para política, arquitetura, processo, responsável, evidência, teste, resultado, descoberta, ação e reteste.
- Utilize os mapeamentos da CSA e o STAR para materiais de IA como auxílio; verifique o escopo exato e o nível de garantia de qualquer alegação externa.
- Não invente certificações nem alegue conformidade com base apenas em um questionário preenchido.

Tema de controle	Exemplos de evidências esperadas
Governança e prestação de contas	Política de IA, funções, inventário, classificação de risco, treinamento, exceções, supervisão
Dados e privacidade	Linhagem, direitos, classificação, minimização, qualidade, acesso, retenção, eliminação
Ciclo de vida do modelo/sistema	Requisitos, cartões, validação, desenvolvimento seguro, versões, aprovações, alterações
Segurança	Modelo de ameaças, identidade, fornecedor, testes, registro de logs, incidentes, resiliência
IA responsável	Avaliação de impacto, equidade, transparência, supervisão humana, reclamações/reparação
Garantia	Mapeamento de controle, populações, evidências, revisão independente, resultados, métricas, melhoria

26. Ferramentas de segurança e garantia de IA de código aberto

As ferramentas de código aberto podem melhorar a repetibilidade, mas não garantem conformidade, segurança, imparcialidade ou aceitação comercial.

Ferramenta	Propósito
Garak	Estrutura de varredura e sondagem de vulnerabilidades LLM
Promptfoo	Avaliação de prompts, modelos, RAG e equipes vermelhas
Giskard	Testes e análise de vulnerabilidades para sistemas de aprendizado de máquina (ML) e aprendizado de máquina (LLM).
PyRIT	Identificação de riscos e orquestração de testes de intrusão para IA generativa.
Inspecionar IA	Avaliações reproduzíveis de modelos de IA
Caixa de ferramentas de robustez adversária	Ataques e defesas de aprendizado de máquina adversário para pesquisa autorizada
Guarda LLM	Scanners de entrada e saída para aplicações LLM
Presídio	Detecção e desidentificação de informações de identificação pessoal
IA de guarda-corpos	Validação estruturada e mecanismos de proteção para os resultados do modelo.
Avaliações da OpenAI	Framework de código aberto para avaliação de modelos e sistemas
Langfuse	Rastreamento, gerenciamento imediato e avaliação de LLM de código aberto
MLflow	Rastreamento de experimentos, registro de modelos, linhagem e registros de implantação
Evidentemente	Monitoramento da qualidade dos dados, da deriva e do modelo
Verificações profundas	Validação de dados e modelos para aplicações de aprendizado de máquina e aprendizado de máquina.
ModelScan	Análise estática de arquivos de modelo serializados
Gitleaks	Descoberta secreta no código-fonte e no histórico.
Curiosidades	Análise de vulnerabilidades, segredos, dependências, imagens e configurações.
ATLAS MITRE	Base de conhecimento sobre táticas e técnicas adversárias contra sistemas de IA

Autorização e segurança: Utilize as ferramentas somente em sistemas, modelos, contas, repositórios, dados e provedores que você possui ou para os quais está expressamente autorizado a testar. Comece com laboratórios isolados e dados sintéticos. Defina limites de solicitação, custo, tempo, conteúdo e parada. Proteja credenciais, avisos, resultados e descobertas.

26.1 Garak

Objetivo: Framework para análise e verificação de vulnerabilidades do LLM. Projeto oficial: [Garak](#)

Início rápido e seguro: Instale em um ambiente isolado; selecione um modelo de laboratório e um pequeno conjunto de sondas aprovadas; proteja os avisos e as saídas; valide os resultados manualmente.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissões, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.2 Promptfoo

Objetivo: Avaliação de prompts, modelos, RAG (Raiz, Verde e Gramática) e equipes vermelhas. Projeto oficial: [Promptfoo](#)

Início rápido e seguro: Crie um pequeno conjunto de testes YAML com o comportamento esperado; use dados sintéticos; execute localmente; revise as falhas; adicione o conjunto ao controle de versão e à integração contínua (CI).

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.3 Giskard

Objetivo: Testes e varredura de vulnerabilidades para sistemas de aprendizado de máquina (ML) e aprendizado de máquina de baixo nível (LLM). Projeto oficial: [Giskard](#)

Início rápido e seguro: Conecte apenas um modelo de teste e um conjunto de dados aprovados; execute varreduras direcionadas; revise as suposições e os falsos positivos; preserve o relatório e realize um novo teste de correção.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26,4 PyRIT

Objetivo: Identificação de riscos e orquestração de ataques de equipe vermelha para IA generativa. Projeto oficial: [PyRIT](#)

Início rápido e seguro: Utilize um alvo de laboratório e regras de conduta documentadas; comece com objetivos inofensivos; limite as solicitações e os custos; revise os históricos escolares; nunca teste terceiros sem permissão.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.5 Inspeccionar IA

Objetivo: Avaliações reproduzíveis de modelos de IA. Projeto oficial: [Inspect AI](#)

Início rápido e seguro: Defina uma tarefa, conjunto de dados, solucionador e avaliador; fixe as versões; execute em um modelo aprovado; mantenha registros, configuração, resultados e limitações.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.6 Caixa de Ferramentas de Robustez Adversarial

Objetivo: Ataques e defesas de aprendizado de máquina adversário para pesquisa autorizada.

Projeto oficial: [Adversarial Robustness Toolbox](#)

Início rápido e seguro: Utilize um modelo local simplificado e dados sintéticos; selecione uma única ameaça; compare os resultados iniciais e os resultados obtidos com a defesa; documente a aplicabilidade e as limitações.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permisões, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.7 LLM Guarda

Finalidade: Scanners de entrada e saída para aplicações LLM. Projeto oficial: [LLM Guard](#).

Início rápido e seguro: Teste os scanners em prompts sintéticos antes da produção; ajuste os limites; meça os casos perdidos e bloqueados; use-os como uma camada, não como o único controle.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permisões, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.8 Presídio

Objetivo: Detecção e desidentificação de informações de identificação pessoal. Projeto oficial: [Presidio](#)

Início rápido e seguro: Execute em amostras sintéticas; configure os reconhecedores para os dados e o idioma; revise falsos positivos e falhas; proteja a saída do analisador.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permisões, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.9 Guardrails AI

Objetivo: Validação estruturada e salvaguardas para as saídas do modelo. Projeto oficial: [Guardrails AI](#)

Início rápido e seguro: defina um esquema de saída e validadores; teste casos válidos, inválidos e adversários; falhe com segurança; registre as decisões de validação sem expor conteúdo sensível.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permisões, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.10 Avaliações OpenAI

Objetivo: Framework de código aberto para avaliação de modelos e sistemas. Projeto oficial: [OpenAI Evals](#)

Início rápido e seguro: Crie um pequeno conjunto de avaliação privado; defina critérios mensuráveis; execute uma avaliação inicial e uma avaliação de viabilidade; inspecione as falhas; proteja os dados e as credenciais dos testes.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permisões, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.11 Langfuse

Objetivo: Rastreamento, gerenciamento de prazos e avaliação de projetos de mestrado em direito (LLM) de código aberto. Projeto oficial: [Langfuse](#)

Início rápido e seguro: Hospede você mesmo ou configure um ambiente aprovado; oculte campos sensíveis; rastreie um fluxo de trabalho de laboratório; defina acesso e retenção; crie um pequeno painel de controle de qualidade.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.12 MLflow

Finalidade: Rastreamento de experimentos, registro de modelos, linhagem e registros de implantação. Projeto oficial: [MLflow](#)

Início rápido e seguro: Use um projeto local; registre parâmetros, referência do conjunto de dados, métricas, artefatos, proprietário e aprovação; registre apenas um modelo testado; restrinja as alterações no registro.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.13 Evidentemente

Objetivo: Monitoramento da qualidade dos dados, deriva e modelos. Projeto oficial: [Evidentemente](#).

Início rápido e seguro: Crie conjuntos de dados sintéticos de referência e atuais; execute um relatório; defina limites de ação; investigue a deriva antes de re-treinar ou reverter.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.14 Verificações profundas

Objetivo: Validação de dados e modelos para aplicações de aprendizado de máquina e aprendizado de máquina. Projeto oficial: [Deepchecks](#)

Início rápido e seguro: Execute um conjunto de testes selecionado em dados aprovados; revise as verificações com falha e sua relevância; registre as exceções; execute novamente após a correção.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.15 ModelScan

Finalidade: Leitura estática de arquivos de modelos serializados. Projeto oficial: [ModelScan](#)

Início rápido e seguro: Analise os artefatos do modelo baixados em quarentena; verifique a origem e o hash; investigue os avisos; nunca carregue um artefato não confiável apenas para testá-lo.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.16 Gitleaks

Objetivo: Descoberta de segredos no código-fonte e no histórico. Projeto oficial: [Gitleaks](#).

Início rápido e seguro: Analise um repositório autorizado; valide as descobertas; revogue as credenciais de teste expostas; remova com segurança; adicione medidas de prevenção; analise novamente.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.17 Curiosidades

Finalidade: Varredura de vulnerabilidades, segredos, dependências, imagens e configurações.

Projeto oficial: [Trivy](#)

Início rápido e seguro: Analise um repositório ou imagem de um serviço de IA autorizado; valide a acessibilidade e o contexto; corrija ou aprove uma exceção com prazo determinado; analise novamente.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

26.18 MITRE ATLAS

Objetivo: Base de conhecimento sobre táticas e técnicas adversárias contra sistemas de IA. Projeto oficial: [MITRE ATLAS](#)

Início rápido e seguro: mapeie a arquitetura do laboratório para as técnicas relevantes; selecione medidas de mitigação e detecção; crie um cenário de simulação; não considere o catálogo como uma lista de verificação completa.

Manter: autorização por escrito, alvo e versão, ambiente, dados, identidade/permissoes, ferramenta/versão/configuração, casos de teste, limites, data, registros, resultados, validação do analista, limitações, constatação, correção e reteste.

27. Manual de Governança de IA para Gestores

Os gestores criam valor ao definir direitos de decisão, limitar a autoridade, exigir provas e impedir trabalhos inseguros.

Pergunta do gerente	Resposta forte	Bandeira vermelha
Por que usar IA?	Necessidade definida, benefício, alternativa, proprietário, sucesso e medidas de parada.	Tecnologia em busca de um problema
Quem pode ser prejudicado?	Pessoas afetadas, gravidade, probabilidade, voz, reparação	Apenas o usuário pagante é considerado.
O que ele pode fazer?	Dados documentados, decisões, ferramentas, permissões, limites	Agentes desconhecidos, integrações ou uso oculto
O que comprova a prontidão?	Testes semelhantes aos de produção, limites, falhas, desafio independente	Apenas demonstração ou reclamação do fornecedor
Onde está o ser humano?	Supervisão competente, informada, autorizada e ponderada.	Aprovação por carimbo
O que altera o risco?	Inventário, monitoramento, lista de gatilhos, regressão, reversão	Atualizações automáticas de modelos sem revisão
Quem aceita o risco residual?	Autoridade nomeada no âmbito do apetite, condições e prazo de validade.	O desenvolvedor assume sozinho o risco comercial/jurídico.

27.1 Ritmo operacional

- Semanalmente: incidentes graves, abuso ativo, ferramentas/dados não autorizados, descobertas críticas, mudanças de provedor e exceções de risco.
- Mensalmente: reconciliação de inventário, limites de monitoramento, reclamações, desvios, falhas de avaliação, permissões de ferramentas, gastos e ações em atraso.
- Trimestral: risco de portfólio, grupos afetados, concentração de fornecedores, supervisão humana, temas de segurança (red team), mudanças legais e candidatos à aposentadoria.
- A cada mudança substancial: remapear o sistema, reavaliar o impacto/ameaça/privacidade, executar novas avaliações relevantes, aprovar, implementar gradualmente e preservar as evidências.

27.2 Perguntas que os líderes devem responder

- Quais sistemas de IA poderiam afetar materialmente pessoas, dinheiro, segurança, direitos, decisões regulamentadas, operações críticas ou dados confidenciais?
- Quais usos são proibidos, mesmo que tecnicamente possíveis?
- A organização consegue desativar ferramentas, suspender decisões, notificar pessoas, corrigir registros e se recuperar de uma falha de modelo/provedor?
- Será que os incentivos estão recompensando a velocidade ou o engajamento em detrimento da segurança e da verdade?
- Os funcionários podem expressar suas preocupações sem sofrer represálias, e as preocupações não resolvidas ficam visíveis para os tomadores de decisão?

28. Guia de Carreira para Analista Júnior de Risco e Segurança em IA

Os analistas juniores agregam valor criando inventários precisos, mapeamentos de sistemas claros, testes reproduzíveis, descobertas úteis e limites honestos.



Junior analysts become job-ready by producing safe, traceable work

Figura 10. Percurso de risco e segurança da IA para iniciantes

28.1 Cargos de nível inicial

- Analista Júnior de Governança de IA ou IA Responsável
- Analista de Risco de IA / Risco de Modelo
- Analista de Segurança de IA ou Segurança GenAI
- Analista de GRC/Conformidade com foco em IA
- Analista de Governança de Dados ou Privacidade
- Analista de Risco de IA de Terceiros
- Analista de Avaliação de IA / Confiança e Segurança
- Analista de Garantia de Segurança

28.2 Trabalho diário

Descubra casos de uso de IA e concilie o inventário em compras, código, APIs, identidade, rede, despesas e entrevistas.

Sistema de documentos/fluxos de dados, pessoas afetadas, limites de uso, fornecedores, permissões e supervisão humana.

Mapear os requisitos NIST, ISO, OWASP, CSA, legais, contratuais e internos para controles e evidências.

Realizar avaliações e testes de segurança autorizados; validar resultados e proteger evidências.

Analisar a documentação do fornecedor, os termos, os modelos de fichas técnicas, os relatórios de garantia de qualidade, os incidentes, as alterações e as responsabilidades do cliente.

Redija as conclusões em linguagem simples; atribua ações; realize novos testes; construa métricas com populações e limitações conhecidas.

Apoiar cronogramas de incidentes de IA, revisão de decisões afetadas, ações corretivas e lições aprendidas.

28.3 Evidências do currículo

- Mapa de fluxo de dados e sistema em uma página com limites de confiança.
- Método de IA para inventário e classificação de risco em uma empresa fictícia.
- Avaliações de impacto, ameaças, privacidade e fornecedores.
- Plano de avaliação com limiares de aceitação e resultados reproduzíveis.
- Três achados com condição, evidência, risco, causa, ação, proprietário e reteste.
- Memorando para o gerente explicando a decisão de prosseguir, prosseguir condicionalmente, realizar um projeto piloto ou não prosseguir.
- Apenas capturas de tela/configurações anonimizadas; identifique claramente o trabalho como ficção e conteúdo educativo.

29. Laboratório ficcional, Plano de trinta dias e entrevistas

Uma aplicação fictícia de IA pode demonstrar governança, testes, segurança e comunicação sem colocar em risco pessoas ou sistemas reais.

Regra do laboratório: Utilize modelos de teste locais ou aprovados, dados sintéticos, contas isoladas, orçamentos fixos e autorização por escrito. Nunca teste um serviço público, empregador, empresa de entrevistas ou modelo de terceiros além do seu programa publicado e da permissão concedida.

29.1 Laboratório de Portfólio

- Crie uma empresa fictícia com 80 funcionários e defina um assistente interno de políticas de RH com a metodologia RAG (Verdadeiro, Autêntico e Genético). Esse assistente poderá explicar as políticas da empresa, mas não poderá tomar decisões de contratação.
- Descreva a finalidade, os usos proibidos, as pessoas afetadas, o nível de risco, a matriz RACI, o inventário, a escolha do modelo/fornecedor e o processo de aprovação.
- Criar documentos de política sintéticos, incluindo um arquivo malicioso de injeção indireta; documentar a proveniência, as ACLs, a ingestão, a retenção e a exclusão.
- Defina os limites de confiança entre dados/modelo/RAG/ferramenta/humano e crie um modelo de ameaças baseado em MITRE ATLAS/OWASP.
- Elabore casos de avaliação para fundamentação, citação, privacidade, imparcialidade/acessibilidade, injeção imediata, aconselhamento inseguro e uso irrestrito.
- Utilize Promptfoo, Garak, Giskard ou Inspect AI em um teste isolado; limite a atividade; valide os resultados manualmente.
- Correção de ACLs de recuperação, separação de instruções, validação de saída, princípio do menor privilégio, registro de logs, limites e escalonamento; execução repetida.
- Elabore um documento de garantia da qualidade, três conclusões, uma decisão sobre o risco residual, um painel de monitoramento, uma simulação de incidente e uma lista de verificação para desativação.
- Publique apenas evidências sintéticas e higienizadas e explique o que o laboratório não comprova.

29.2 Plano de trinta dias

Dias	Foco	Entregável
1–3	Noções básicas de IA e características confiáveis	Mapa conceitual e glossário
4–6	NIST AI RMF e governança	RACI, esboço da política, inventário
7–9	Mapeamento de casos de uso e impacto	Mapeamento do sistema e avaliação de impacto
10–12	Governança de dados/modelos	Conjunto de dados e cartões de modelo
13–15	Ameaças, OWASP, ATLAS	Modelo de ameaças e requisitos de segurança
16–18	RAG, agentes, identidade, MCP	Confiança nos limites e na política de ferramentas
19–21	Avaliação e equipe vermelha	Plano de teste, limites, resultados
22–24	Privacidade, equidade, transparência	Três documentos de revisão
25–27	Monitoramento, incidentes, garantia	Painel de controle, teste de mesa, teste de controle
28–30	Portfólio e entrevistas	Memorando do gerente e cinco histórias STAR

29.3 O que é o NIST AI RMF?

Uma estrutura voluntária para gerenciar os riscos da IA por meio de Governança, Mapeamento, Mensuração e Gestão. Ela se concentra nos riscos para pessoas, organizações e sociedade.

29.4 Risco do modelo versus risco do sistema?

O risco de modelo diz respeito ao comportamento do modelo; o risco de sistema inclui pessoas, dados, interfaces, ferramentas, infraestrutura, fornecedores, processos e decisões do mundo real.

29.5 O que é injeção imediata?

Conteúdo não confiável é interpretado como instruções que alteram o comportamento ou acessam dados e ferramentas. Trate o conteúdo como dados, restrinja a autoridade, valide as ações e teste as alternativas.

29.6 Como você avalia um LLM?

Defina o uso e os danos, crie casos representativos e limites, teste o sistema versionado completo, revise as falhas e incertezas, aprove as condições e monitore as mudanças.

29.7 O que é RAG?

A geração aumentada por recuperação recupera conteúdo externo e o fornece a um modelo. Ela adiciona riscos de origem, acesso, envenenamento, injeção, citação, atualização e exclusão.

29.8 Por que a supervisão humana é difícil?

Um revisor pode não ter tempo, informação, habilidade, independência ou autoridade suficientes e pode confiar demais na automação. A supervisão deve ser planejada e testada.

29.9 O que é um inventário de IA?

Um registro próprio de uso, finalidade, pessoas, tecnologia, modelos, dados, fornecedores, impacto, aprovações, controles, monitoramento e desativação.

29.10 Como as ferramentas comprovam a conformidade?

Não. As ferramentas produzem evidências que um analista deve definir o escopo, validar, interpretar em relação aos requisitos e conectar às decisões e à remediação.

29.11 Como você relata uma descoberta?

Condição do estado, evidências/população, requisitos, impacto nos negócios e nas pessoas, causa, recomendação, responsável, data de vencimento, proteção provisória e novo teste.

29.12 O que caracteriza um bom analista júnior?

Curiosidade, abrangência cuidadosa, respeito pelas pessoas e pelos dados, testes reproduzíveis, escrita clara, incerteza honesta, uso seguro de ferramentas e acompanhamento.

30. Modelos, Glossário, Índice e Referências

Formulários reutilizáveis e fontes confiáveis ajudam a transformar conceitos em trabalho consistente.

30.1 Inventário de casos de uso de IA

Campo	Entrada
ID do sistema/uso, status, proprietário, patrocinador	
Finalidade, benefício, usuários, pessoas afetadas	
Decisões/conteúdo, autonomia, usos proibidos	
Modelo/provedor/versão/configuração	
Dados, direitos, sensibilidade, localização, retenção	
RAG, agentes, ferramentas, APIs, MCP	
Nível de impacto, leis/contratos, avaliações	
Supervisão humana, apelação, reparação	
Avaliação, aprovação, condições	
Monitoramento, incidentes, mudanças, aposentadoria	

30.2 Avaliação do impacto e dos riscos da IA

Campo	Entrada
Contexto, pessoas, alternativas, dependência	
Benefícios e medidas de sucesso	
Danos: direitos, segurança, financeiros, sociais, operacionais	
Probabilidade, gravidade, escala, reversibilidade, incerteza	
Grupos afetados e acessibilidade	
Limitações de dados/modelo/fornecedor	
Limites de controle e avaliação	
Supervisão humana e contestabilidade	
Risco residual e autoridade de decisão	
Acione os gatilhos e o prazo de validade da revisão.	

30.3 Documento de trabalho de avaliação de IA

Campo	Entrada
Reivindicação, risco, requisito, limite	
Versões de sistema/modelo/prompt/ferramenta	
Ambiente e autorizações	
Origem e população do conjunto de dados	
Casos, avaliadores, rubrica humana, amostra	
Aleatoriedade/repetições e confiança	
Resultados, falhas, análise de subgrupos	
Limitações e exclusões conhecidas	
Decisão, condições, conclusões	
Reteste de correção e regressão	

30.4 Registro de incidentes e alterações de IA

Campo	Entrada
ID do caso/alteração, responsável, gravidade	

Campo	Entrada
Sistema/versão/pessoas/decisões afetadas	
Prompt, contexto, recuperação, ferramentas, identidades	
Cronograma, preservação de evidências, provedor	
Contenção e proteção das pessoas afetadas	
Correção, reversão, reparação, notificação	
Causas principais/contribuintes	
Versão confiável, validação, reversão	
Reavaliação e monitoramento de riscos	
Lições, ações, reteste, encerramento	

30.5 Glossário

Prazo	Significado
Agente	Software com inteligência artificial que planeja e utiliza ferramentas para atingir um objetivo.
IA RMF	Estrutura de Gestão de Riscos de Inteligência Artificial do NIST.
AICM	Matriz de Controles de IA da CSA.
Confabulação	Conteúdo gerado plausível, porém falso ou sem fundamento.
Incorporação	Representação numérica usada para comparar significado ou semelhança.
Avaliação	Medição estruturada de reivindicações e riscos definidos do sistema.
Modelo de fundação	Modelo amplo que pode ser adaptado a muitas tarefas subsequentes.
Firmeza	Grau em que a produção é apoiada por fontes fornecidas ou autorizadas.
Supervisão humana	Capacidade humana significativa de compreender, supervisionar, intervir, anular ou interromper algo.
Avaliação de impacto	Análise dos efeitos pretendidos e previsíveis sobre as pessoas e as organizações.
Inferência	Utilizar um modelo treinado para produzir uma previsão ou resultado.
MCP	O Model Context Protocol é um padrão para conectar aplicações de IA a ferramentas e dados.
Cartão modelo	Documentação estruturada sobre o uso pretendido, desempenho, limites e outros dados.
Deriva do modelo	Alteração no desempenho ou comportamento conforme os dados ou o contexto mudam.
injeção imediata	Instruções não confiáveis alteram o comportamento do modelo ou do aplicativo.
TRAPO	Geração aumentada por recuperação.
Equipe vermelha	Avaliação adversária autorizada de riscos e modos de falha.
Sistema sociotécnico	Tecnologia e as pessoas, regras, instituições e contexto que a envolvem.
Placa do sistema	Documentação completa do sistema de IA, incluindo avaliação, riscos e limitações.
Banco de dados vetorial	Serviço de armazenamento e busca para imagens incorporadas e metadados associados.

30.6 Índice de assuntos

Assunto	Capítulo
Agentes/autonomia	16, 19
AICM	25
Garantia/evidência	22–25
Dados/privacidade	11, 20
Lei de IA da UE	2
Imparcialidade/supervisão	21
Perfil GenAI	8
Inventário/ciclo de vida	10
ISO 42001 / 23894	9
Gerente	27
MCP / ferramentas	19
Modelos/fornecedores	12–13
Monitoramento/incidentes	23
NIST AI RMF	3–7
Ferramentas de código aberto	26
OWASP / modelo de ameaças	14–16
TRAPO	17
Testes / equipe vermelha	6, 22
Analista júnior	28–29

30.7 Referências oficiais

- [Estrutura de Gestão de Riscos de IA do NIST](#)
- [NIST AI RMF 1.0 PDF](#)
- [Manual de IA RMF do NIST e AIRC](#)
- [Perfil de IA generativo NIST AI 600-1](#)
- [Taxonomia de Aprendizado de Máquina Adversarial do NIST](#)
- [ISO/IEC 42001:2023](#)
- [ISO/IEC 23894:2023](#)
- [Página de políticas da Lei de IA da UE](#)
- [Cronograma oficial de implementação da Lei de IA da UE](#)
- [OWASP Top 10 para candidaturas a LLM em 2025](#)
- [OWASP Top 10 para Aplicações Agentes 2026](#)
- [Projeto de Segurança OWASP GenAI](#)
- [ATLAS MITRE](#)
- [Recursos da Matriz de Controles de IA da CSA](#)
- [CSA STAR para IA](#)
- [Princípios de IA da OCDE](#)
- [Recomendação da UNESCO sobre a Ética da IA](#)
- [Recursos de IA da CISA](#)
- [Inspeção do Instituto de Segurança de IA do Reino Unido](#)

Lembrete final: as leis, normas, ameaças, comportamento dos modelos, fornecedores, termos, ferramentas e orientações oficiais sobre IA mudam rapidamente. Verifique a fonte atual, a versão do sistema, os fatos e a jurisdição antes da implementação, avaliação, implantação ou aceitação de riscos.